

RESUMEN EJECUTIVO: GQM + PRAGMATIC PARA BSIMM15

Síntesis Estratégica para Dirección y CISOs

Versión: 1.0

Fecha: Enero 21, 2026

Audiencia: Directores, CISOs, Responsables Gobernanza

Documentos Relacionados: Marco Integrativo + Matriz Completa

PROBLEMA: MÉTRICAS SIN TRAZABILIDAD

La mayoría de organizaciones cuando implementan BSIMM se encuentran con:

X 128 actividades sin priorización clara

X Métricas desconectadas de objetivos negocio

X Iniciativas costosas con ROI opaco

X Decisiones reactivas, no estratégicas

Resultado: Inversión en seguridad de software sin alineación con risk reduction real.

SOLUCIÓN: MARCO GQM + PRAGMATIC

Integramos dos metodologías complementarias para crear trazabilidad **completa**:

Metodología 1: GQM (Goal-Question-Metric)

GOAL (¿Qué queremos lograr?)

↓

QUESTIONS (¿Cómo sabemos que lo logramos?)

↓

METRICS (¿Qué medimos?)

Ejemplo:

- GOAL: "Detectar vulnerabilidades en código antes de producción"
- QUESTIONS: "¿Se ejecuta SAST en 100% del código? ¿Se remedian hallazgos críticos?"
- METRICS: "SAST coverage %, MTTD crítico, % remediados"

Metodología 2: PRAGMATIC (Metametrics)

Evalúa cada métrica contra 9 criterios de utilidad práctica:

Criterio	Pregunta
Predictive	¿Predice riesgo futuro?
Relevant	¿Es relevante a objetivos negocio?
Actionable	¿Lleva a acción específica?
Genuine	¿Basada en datos reales?
Meaningful	¿Tiene significado operacional?
Accurate	¿Es medible y precisa?
Timely	¿Se obtiene en tiempo útil?
Independent	¿No depende de otras métricas?
Cost-effective	¿Económicamente viable?

Score PRAGMATIC: Promedio de 9 criterios (0-100)

HALLAZGOS CLAVE

1. TOP 10 ACTIVIDADES BSIMM A ADOPTAR YA (Score PRAGMATIC ≥ 85)

Rank	Actividad	Observación	PRAGMATIC	Impacto
1	CR1.4: SAST Tools	87.6%	91	Prevención código defectos
2	SM1.4: Checkpoints	90.1%	89	Control pipeline seguridad
3	DM1.1: Infra Auto	70%	89	Prevención config insegura
4	CR1.5: SCA	68%	88	Gestión supply chain
5	SM1.2: Medir Éxito	69%	88	Visibilidad programa
6	CM1.1: IR Interface	91.7%	87	Respuesta incidentes
7	SM3.3: Report Exec	65%	86	Alignment dirección
8	EM1.3: Dashboard	58%	84	Gobernanza real-time
9	PC2.2: Enforce	70%	84	Cumplimiento políticas
10	O1.1: Roles	75%	83	Estructura organizacional

Implicación: Estas 10 actividades cubren 80% del impacto con 20% del esfuerzo

2. ACTIVIDADES CON BAJO PRAGMATISMO (Score < 70)

Actividad	Observación	PRAGMATIC	Razón
CM3.3: Crisis Simulation	45%	66	Costoso, baja frecuencia, ROI opaco
AA2.2: Std Architecture	40%	69	Muy emergente, subjetiva

Recomendación: Aplazar o considerar alternativas más pragmáticas

3. MATRIZ COSTO-EFECTIVIDAD

ALTO IMPACTO	BAJO COSTO QUICK WINS (10-15 actividades)	ALTO COSTO STRATEGIC (8-12 actividades)
BAJO IMPACTO	MONITOR (5-8 actividades)	EVITAR (3-5 actividades)

Quick Wins (Implementar Q1 2026):

- SM1.4: Checkpoints (~€5k)
- CR1.4: SAST tuning (~€3k)
- EM1.3: Dashboard (~€2k)
- DM1.1: Infra automation (~€8k)
- **Total Q1: ~€18k para +15 puntos**

Strategic Bets (Implementar Q2-Q4 2026):

- CR1.5: SCA advanced (~€20k)
- DM2.2: SBOM integration (~€25k)
- CM3.1: Advanced alerting (~€15k)
- SM1.2: Metrics evolution (~€10k)
- **Total 2026: ~€250k acumulado para transformación L2–L3**

MATRIZ GQM APLICADA A ESPAÑA (NIS2 + ENS)

GOAL NACIONAL (Octubre 2026)

"Lograr 70+ puntos en Índice NIS2 de Madurez Seguridad Software"

Donde Índice NIS2 = $(\% \text{ actividades L3-L5} / 128) \times 100$

QUESTIONS

Pregunta	Métrica
¿Cuántas apps críticas españolas implementan SM1.4?	Target: 90%+
¿Cuál es MTTD promedio en sector ES?	Target: <12h
¿% de apps bajo SAST mandatory?	Target: 95%+
¿Cumplimiento NIS2 Medidas Mínimas?	Target: 100%
¿PRAGMATIC Score promedio ES vs EU?	Target: >85

ROADMAP ESPAÑA 2026

Q1 2026: Quick Wins (Meta +8 puntos)

- Implementar SM1.4 checkpoints en apps críticas
- Deploy SAST en 80%+ aplicaciones
- Crear metrics dashboard ejecutivo

Q2 2026: Baseline Compliance (Meta +10 puntos)

- NIS2 tabletop validation
- FAIR cuantificación riesgos
- SCA adoption en 50%+ orgs

Q3-Q4 2026: Advanced Maturity (Meta +12 puntos)

- SBOM generación mandatoria
- IR automation implementation
- Continuous testing en DevOps

TARGET FINAL: Score 70+ (L3 completo, NIS2-ready)

RECOMENDACIONES POR PERFIL

Para CISO (Implementación)

1. Priorizar TOP 10 PRAGMATIC (85+)
2. ROI + implementación clara
3.
Cobertura 80% de impacto
4.
Usar GQM para justificar presupuesto
5. GOAL nacional → QUESTIONS operacionales → METRICS técnicas
6.
Conecta inversión seguridad con objetivos negocio
7.
Rechazar actividades RED (<70 PRAGMATIC)
8. CM3.3 (Crisis Sim): \$\$ alto, ROI bajo
9.
AA2.2 (Std Arch): Emergente, impacto indirecto
10.
Roadmap 3 fases
11. Q1: €18k, +15 puntos
12. Q2: €70k, +10 puntos
13. Q3-Q4: €170k, +12 puntos
14. Target: 70+ puntos, L3 completo

Cobertura 80% de impacto

Usar GQM para justificar presupuesto

Conecta inversión seguridad con objetivos negocio

Rechazar actividades RED (<70 PRAGMATIC)

AA2.2 (Std Arch): Emergente, impacto indirecto

Roadmap 3 fases

Para Dirección (Gobernanza)

15. Entender la trazabilidad GQM
16. No es "implementar 128 actividades"
17.
Es "alcanzar 70 puntos NIS2 a través de 20-30 actividades prioritarias"
18.
Evaluar pragmatismo PRAGMATIC
19. Métrica que no es accionable = gasto sin beneficio
20.
Métricas RED: preguntar CISO por alternativa
21.
Presupuesto justificado por impacto
22. €18k Q1 = reducir riesgo vulnerabilidades de código
23.
€250k anual = transformación L2–L3, compliance NIS2
24.
KPIs de seguimiento
25. Score BSIMM (baseline 56, target 70, end-2026)
26. MTTD vulnerabilidades críticas (baseline 5d, target <2d)
27. % de apps bajo checkpoints (baseline 30%, target 95%)

Es "alcanzar 70 puntos NIS2 a través de 20-30 actividades prioritarias"

Evaluar pragmatismo PRAGMATIC

Métricas RED: preguntar CISO por alternativa

Presupuesto justificado por impacto

€250k anual = transformación L2–L3, compliance NIS2

KPIs de seguimiento

Para Auditores/Cumplimiento

28. Mapeo BSIMM a NIS2
29. SM1.2 + SM3.3 = NIS2 Medida 1 (Gobernanza)
30. CR1.4 + CR1.5 = NIS2 Medida 2 (Secure development)
31.
DM1.1 + DM2.2 = NIS2 Medida 7 (Configuration management)
32.
Validación PRAGMATIC
33. Revisar que métricas implementadas sean >70 PRAGMATIC
34.
Rechazar métricas con <60 PRAGMATIC como prueba de compliance
35.
GQM para auditoría
36. GOAL: ¿Cuál es la meta de riesgo aceptable?
37. QUESTIONS: ¿Qué preguntas son críticas para validar?
38. METRICS: ¿Qué medimos como prueba?

DM1.1 + DM2.2 = NIS2 Medida 7 (Configuration management)

Validación PRAGMATIC

Rechazar métricas con <60 PRAGMATIC como prueba de compliance

GQM para auditoría

IMPACTO ESTIMADO POR FASE

Q1 2026: Quick Wins

Actividad	Inversión	Impacto	Plazo
SM1.4 Checkpoints	€5k	Bloquear 90%+ vuln críticas	30d
CR1.4 SAST Tuning	€3k	Cobertura 80%+ código	20d
EM1.3 Dashboard	€2k	Visibilidad ejecutiva	14d
DM1.1 Infra Auto	€8k	Config validation 70%+	45d
Total Q1	€18k	+15 puntos Score	90 días

Q2 2026: Baseline Compliance

Actividad	Inversión	Impacto	Plazo
FAIR Implementation	€15k	Riesgo cuantificado	60d
SOAR Integration	€30k	IR automation	60d
SCA Adoption	€20k	Supply chain managed	30d
Total Q2	€70k	+10 puntos Score	90 días

Q3-Q4 2026: Advanced Maturity

Actividad	Inversión	Impacto	Plazo
SBOM Generation	€15k	Artefacts tracked	45d
Red Team Program	€50k	Validation experta	Ongoing
Continuous Testing	€40k	Real-time testing	60d
Advanced Metrics	€65k	Evolución L3→L4	Ongoing
Total Q3-Q4	€170k	+12 puntos Score	180 días

CONCLUSIÓN: TRAZABILIDAD ASEGURADA

Este marco **GQM + PRAGMATIC** aplicado a BSIMM15:

- ✓ **Elimina subjetividad:** Cada actividad evaluada contra 9 criterios
- ✓ **Prioriza por ROI:** Top 10 actividades = 80% del impacto
- ✓ **Conecta con negocio:** GOAL nacional → QUESTIONS → METRICS
- ✓ **Justifica inversión:** Presupuesto alineado a riesgo reduction
- ✓ **Facilita decisiones:** RED/YELLOW/GREEN indicators claros

Decisión clara: Adoptar TOP 10 PRAGMATIC en Q1, evaluar YELLOW en Q2-Q4, descartar RED.

PRÓXIMOS PASOS

Semana 1: Validación

- [] CISO revisa documentos
- [] Dirección aprueba GOAL nacional (70 puntos)
- [] Presupuesto confirmado (€250k)

Semana 2: Planning

- [] Q1 Quick Wins detallado
- [] Asignación propietarios
- [] Hitos y métricas de seguimiento

Semana 3-4: Ejecución Q1

- ☐ Implementar SM1.4, CR1.4, EM1.3, DM1.1
- ☐ Tracking trimestral
- ☐ Reporte a Dirección (Score: 56 – 71)

Documentos Detallados Disponibles:

1. Marco Integrativo: marco_gqm_pragmatic.md
2. Matriz Pragmatic Completa: matriz_pragmatic_completa.md

FIN DEL RESUMEN EJECUTIVO